Laporan Insiden RAT dan Ransomware pada Portal Perizinan

Universitas AMIKOM Yogyakarta

Magister Informatika · 2026

Identitas

Butir	Keterangan
Mata kuliah	Cyber Security (Tugas 2)
Dosen pengampu	**Dr. Raden Muhammad Agung Harimurti P., M.Kom.**
Program studi	Magister Informatika, Universitas AMIKOM Yogyakarta
Anggota kelompok	M. Abiyyu Rahman (25.51.1738) Bagas Restya Ermawan (25.51.1779) Elsa Monica Putri (25.51.1809) Linda Sofiana (25.51.1762) Sintia Eka Purwati (25.51.1765)
Lampiran	Contoh Kontrak Pengembangan Portal Perizinan (Kasus A dan B)

Bab 1 Pendahuluan

1.1 Latar belakang

Layanan publik pemerintah semakin bergantung pada aplikasi web yang dibangun dan dikelola vendor pihak ketiga. Hubungan ini menciptakan rantai kepercayaan: masyarakat mempercayai portal resmi, pegawai mempercayai panel admin yang dibuka setiap hari, dan instansi mempercayai vendor yang memegang akses tertinggi. Ketika satu mata rantai gagal, penyerang dapat memakai kepercayaan itu sebagai jalan masuk.

Laporan ini menganalisis skenario insiden pada portal perizinan sebuah pemerintah kota. Penyerang masuk melalui akun superadmin vendor, menyusupkan skrip ke panel admin, menginfeksi PC pegawai dengan Remote Access Trojan (RAT), lalu diam-diam menyebar sampai sekitar 500 PC sebelum melumpuhkan semuanya sekaligus dengan ransomware.

1.2 Rumusan masalah

1. Bagaimana alur serangan berlangsung, dari akses awal sampai kelumpuhan instansi?
2. Siapa saja aktor yang terlibat, apa yang dilakukan masing-masing, dan kontrol apa yang gagal?
3. Bagaimana model pertahanan A.E.G.I.S dapat mendeteksi serangan pada setiap fase?
4. Mitigasi apa yang diperlukan, baik saat insiden maupun jangka panjang, termasuk menjaga layanan tetap berjalan?
5. Pihak mana yang paling bertanggung jawab, jika kontrak dengan vendor mengatur keamanan siber dan jika tidak?

1.3 Tujuan

1. Menyusun kronologi serangan yang rinci dan memetakannya ke model NCSC, Cyber Kill Chain, dan MITRE ATT&CK.
2. Memetakan hierarki aktor beserta peran, tindakan, dan durasinya.
3. Merancang deteksi berbasis A.E.G.I.S dan Hermes AI Agent per fase serangan.
4. Menyusun mitigasi yang langsung menjawab titik gagal dalam skenario.
5. Menganalisis pembagian tanggung jawab secara tidak bias melalui dua contoh kontrak.

1.4 Batasan dan asumsi

- Skenario, nama instansi, nama vendor, dan nama sistem bersifat fiktif. Seluruh angka hari dan jumlah PC adalah asumsi skenario, bukan data insiden nyata.
- Delapan modul pertahanan A.E.G.I.S pada Bab 6 adalah rancangan untuk kasus ini dan belum diuji pada lingkungan produksi.
- Analisis hukum pada Bab 8 adalah analisis akademik, bukan nasihat hukum.

Bab 2 Landasan Teori

2.1 Konsep serangan

- **Watering hole.** Penyerang tidak mendatangi korban, tetapi menyusupi situs yang rutin dikunjungi korban. Berbeda dari drive-by download massal, watering hole adalah operasi tertarget: situs dipilih karena audiensnya.
- **Drive-by compromise.** Browser korban dieksploitasi hanya dengan membuka halaman yang disusupi, tanpa korban mengunduh atau menjalankan berkas secara sadar.
- **Remote Access Trojan (RAT).** Malware yang memberi penyerang kendali jarak jauh atas host: menjalankan perintah, mengambil dan mengirim berkas, merekam ketikan, dan menjadi pijakan ke host lain.
- **Command and Control (C2).** Infrastruktur penyerang yang menerima laporan (beacon) dari RAT dan mengirim perintah. Koneksi dibuka dari dalam jaringan korban ke luar, sehingga firewall yang hanya menyaring lalu lintas masuk tidak menghentikannya.
- **Ransomware dengan pemerasan ganda.** Penyerang mencuri data lebih dulu, lalu mengenkripsi sistem. Korban ditekan dua kali: membayar untuk dekripsi, dan membayar agar data tidak dipublikasikan.
- **Trusted relationship.** Organisasi mewarisi risiko pihak ketiga yang memegang akses ke asetnya. Akses vendor yang sah menjadi jalan masuk yang sulit dibedakan dari aktivitas normal.

2.2 Kerangka analisis

Kerangka	Fungsi dalam laporan ini
Model empat tahap NCSC (Survey, Delivery, Breach, Affect)	Struktur besar alur serangan sesuai soal
Cyber Kill Chain	Tahapan yang lebih rinci, dari reconnaissance sampai actions on objectives
MITRE ATT&CK	Teknik spesifik per langkah, dengan kode teknik (misalnya T1078, T1486)

Kerangka	Fungsi dalam laporan ini
NIST SP 800-61r3	Kerangka respons insiden, diterbitkan April 2025 menggantikan Revisi 2 (2012), selaras dengan fungsi NIST CSF 2.0: Govern, Identify, Protect, Detect, Respond, Recover

2.3 Regulasi yang relevan

Regulasi	Ketentuan yang dipakai
UU 27/2022 tentang Pelindungan Data Pribadi	Pasal 46: pengendali wajib memberitahu subjek data dan lembaga paling lambat 3 x 24 jam saat terjadi kegagalan pelindungan. Pasal 51: prosesor memproses atas perintah pengendali; tanggung jawab beralih ke prosesor hanya bila ia bertindak di luar perintah. (pasal.id, Meridian Hukum)
PP 71/2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik	Pasal 2 ayat (3): PSE lingkup publik meliputi instansi dan institusi yang ditunjuk instansi. Pasal 3: PSE wajib menyelenggarakan sistem secara andal, aman, dan bertanggung jawab. (Justisio)
Perpres 16/2018 tentang Pengadaan Barang/Jasa Pemerintah beserta perubahannya	Pasal 78: sanksi bagi penyedia, antara lain pencairan jaminan, daftar hitam, ganti kerugian, dan denda. (SIP Law Firm)
KUHPerdata	Wanprestasi atas kontrak, serta perbuatan melawan hukum dan kelalaian (Pasal 1365 dan 1366)

2.4 Kasus serupa

Polanya berulang: penyerang memanfaatkan situs resmi atau akses vendor yang dipercaya, lalu bergerak tanpa terdeteksi selama berminggu-minggu.

Tahun	Kasus	Pola	Relevansi dengan skenario
2024	PDNS 2, Indonesia	Ransomware Brain Cipher melumpuhkan pusat data pihak ketiga yang dipakai sekitar 282 instansi; pengelola tidak memiliki backup, pemulihan bergantung pada backup masing-masing instansi	Kelumpuhan layanan publik dan pentingnya cadangan serta situs pemulihan
2020	SolarWinds Orion	Pembaruan perangkat lunak vendor disisipi, menjangkau instansi pemerintah dan infrastruktur kritis; CISA menyebut penyerangnya sabar dan bertahan lama di jaringan korban	Risiko rantai pasok vendor dan penyerang yang menahan diri
2017	KNF, Polandia	Situs regulator keuangan disisipi JavaScript berbahaya untuk menginfeksi bank yang mengaksesnya; situs terinfeksi sejak Oktober 2016 sampai Februari 2017	Watering hole lewat situs otoritas resmi, dengan JavaScript sebagai pembawa
2013	Target, Amerika Serikat	Penyerang masuk memakai credential vendor HVAC yang dicuri, lalu mencuri data kartu pembayaran	Credential vendor sebagai jalan masuk
2013	Department of Labor, Amerika Serikat	Halaman situs pemerintah disusupi untuk memasang RAT Poison Ivy pada pengunjung tertarget	Watering hole dengan muatan RAT, paling mirip skenario ini

Bab 3 Skenario Kasus

3.1 Gambaran sistem

SIPerizinan adalah portal perizinan online milik Dinas Penanaman Modal dan Pelayanan Terpadu Satu Pintu (DPMPTSP) Kota Mahakarya. Portal ini dibangun, di-host, dan dipelihara oleh PT Arunika Data Teknologi berdasarkan kontrak pengadaan (lihat lampiran kontrak). Semua nama bersifat fiktif.

- **Halaman publik:** dipakai masyarakat untuk mengajukan dan memantau permohonan izin.
- **Panel admin:** dibuka setiap hari kerja oleh pegawai DPMPTSP dari PC kantor untuk memverifikasi dan memproses permohonan.
- **Panel superadmin:** dipakai vendor untuk mengelola konfigurasi, tema, plugin, dan pengguna.
- **Jaringan instansi:** sekitar 500 PC pegawai berada dalam satu domain Active Directory, dikelola tim TI instansi, dan terhubung ke internet tanpa pembatasan lalu lintas keluar.

3.2 Hierarki aktor

Aktor disusun dari akses tertinggi ke terendah. Semakin tinggi aksesnya, semakin besar dampak bila akunnya disalahgunakan.

Tingkat	Aktor	Contoh peran	Akses	Kewajiban utama
1	Vendor (superadmin)	Developer dan admin server PT Arunika	Panel superadmin, server, kode sumber, deployment	Membangun, meng-host, menambal, dan mengamankan portal
2	Tim TI instansi	Pranata komputer DPMPTSP	Akun domain admin, seluruh PC, jaringan	Mengelola dan mengamankan PC, akun, dan jaringan instansi
3	Admin instansi	Kepala bidang pelayanan, admin aplikasi	Panel admin, manajemen akun pegawai	Mengawasi layanan dan vendor, mengelola akun operator

Tingkat	Aktor	Contoh peran	Akses	Kewajiban utama
4	Operator instansi	Petugas verifikasi dan back office	Panel admin terbatas	Memproses permohonan setiap hari
5	Masyarakat (user)	Pelaku usaha pemohon izin	Halaman publik dan akun pemohon	Mengajukan permohonan dengan data yang benar

Aktor eksternal: **penyerang** (pelaku), **BSSN** (koordinasi penanganan insiden siber pemerintah), dan **aparat penegak hukum** (penyidikan pidana).

3.3 Aset yang dipertaruhkan

Aset	Isi	Pemilik
Basis data permohonan	Data pribadi pemohon, dokumen usaha, status izin	Instansi (pengendali data)
Portal dan kode sumber	Aplikasi SIPerizinan	Instansi, dikelola vendor
PC dan file server pegawai	Dokumen internal dan arsip layanan	Instansi
Akun domain	Identitas seluruh pegawai	Instansi
Akun superadmin	Kendali penuh atas portal	Vendor

Bab 4 Analisis Serangan

Penyerang berada di dalam sistem selama 30 hari sebelum memicu serangan, dan instansi baru menyadari insiden pada hari ke-33. Selama itu penyerang sengaja tidak merusak apa pun: ia hanya memperluas kendali sampai sekitar 500 PC, lalu melumpuhkan semuanya sekaligus. Notasi H0 adalah hari akses awal; semua angka adalah asumsi skenario.

4.1 Kronologi per fase

Fase 0, pengintaian (H-30 sampai H-1). Penyerang memetakan subdomain portal dan menemukan `admin.siperizinan.mahakarya.go.id` yang terbuka ke internet (T1595). Dari tampilan halaman dan berkas statis, ia mengenali versi framework dan plugin yang dipakai. Penyerang lalu mencari credential milik vendor di kumpulan data kebocoran dan log infostealer yang diperjualbelikan, dan menemukan password akun superadmin milik seorang developer vendor (T1589.001). Password itu juga dipakai developer tersebut di layanan lain yang pernah bocor.

Fase 1, akses awal (H0, Sabtu pukul 02.00). Penyerang login ke panel superadmin memakai credential tersebut (T1078). Panel tidak memakai MFA, tidak dibatasi IP, dan login dari IP luar negeri pada dini hari tidak memicu peringatan apa pun.

Fase 2, pijakan di server dan penyiapan jebakan (H0, satu jam kemudian).

1. Lewat fitur unggah plugin di panel superadmin, penyerang memasang web shell di server (T1505.003). Akses ini tetap ada meskipun password superadmin nanti diganti.
2. Penyerang mendaftarkan domain yang namanya mirip layanan CDN untuk server exploit dan C2 (T1583.001).
3. Penyerang menyisipkan beberapa baris loader ke berkas JavaScript bersama yang dimuat di semua halaman portal (T1608.004). Loader ini selektif: hanya aktif bila pengunjung datang dari alamat IP publik kantor instansi dan sedang membuka panel admin setelah login. Masyarakat tetap mendapat halaman normal.

Karena loader selektif, tidak ada keluhan dari masyarakat dan tidak ada tanda yang terlihat dari luar.

Fase 3, gelombang pertama lewat watering hole (H2 sampai H7). Mulai Senin, setiap operator yang login ke panel admin memuat iframe tersembunyi ke server exploit. Server itu memeriksa versi browser korban:

- Browser yang patch-nya tertinggal langsung dieksploitasi tanpa interaksi pengguna (T1189, T1203).
- Browser yang sudah mutakhir diberi pop-up palsu bertuliskan "Pembaruan sertifikat layanan diperlukan". Operator yang menjalankan berkasnya ikut terinfeksi (T1204.002).

RAT terpasang di folder profil pengguna, mendaftarkan diri di Run key agar aktif setiap kali PC menyala (T1547.001), dan mengirim beacon HTTPS ke C2 setiap beberapa menit dengan jeda acak (T1071.001). Pada H7, sekitar 100 dari sekitar 120 PC pengguna panel admin sudah terinfeksi.

Fase 4, mencuri credential sampai domain admin (H7 sampai H14). RAT merekam ketikan (T1056.001), mengambil password yang tersimpan di browser (T1555.003), dan membaca credential dari memori proses LSASS (T1003.001). Penyerang juga memetakan akun domain, host, dan folder bersama (T1087.002, T1018, T1135).

Titik baliknya terjadi pada H12. Beberapa operator melapor PC mereka lambat. Staf TI datang dan login langsung ke PC itu memakai akun domain admin untuk memperbaikinya, dan credential domain admin pun tertangkap. Sejak saat ini penyerang tidak lagi bergantung pada pegawai yang membuka portal.

Fase 5, penyebaran senyap ke 500 PC (H14 sampai H28). Dengan akun domain admin, penyerang memasang RAT ke PC lain lewat koneksi SMB dan eksekusi layanan jarak jauh (T1021.002, T1569.002). Penyebaran dilakukan bertahap, sekitar 30 PC per hari dan pada jam kerja, agar menyatu dengan aktivitas admin yang normal. Pada H28, sekitar 500 PC sudah dikuasai.

Pada fase yang sama, penyerang mengeluarkan data permohonan dari basis data portal lewat web shell dan dokumen internal dari file server lewat jalur C2 (T1041). Data ini disiapkan sebagai alat pemerasan kedua.

Fase 6, persiapan serangan (H28 sampai H30). Penyerang memetakan lokasi backup: NAS milik instansi di jaringan yang sama, dan berkas backup portal yang disimpan vendor di server yang sama dengan portal. Ia lalu menyiapkan Group Policy untuk menonaktifkan antivirus (T1562.001) dan membuat scheduled task di seluruh PC (T1484.001, T1053.005), serta menyiapkan perintah penghapusan shadow copy (T1490).

Fase 7, serangan serentak (H30, Jumat pukul 23.00). Scheduled task berjalan bersamaan di sekitar 500 PC dan file server, mengenkripsi seluruh berkas (T1486). NAS backup ikut terenkripsi. Lewat web shell, penyerang menghapus berkas portal, basis data, dan backup vendor yang berada di server yang sama (T1485). Di setiap layar muncul catatan tebusan: bayar untuk kunci dekripsi, atau data pemohon dipublikasikan.

Fase 8, dampak (H31 sampai H33). Sabtu pagi, masyarakat mengeluh di media sosial bahwa portal tidak bisa dibuka. Senin pukul 07.30, pegawai tiba dan mendapati semua PC menampilkan catatan tebusan. Tidak ada PC yang bisa dipakai, panel admin mati, backup tidak tersedia, dan layanan perizinan berhenti total.

4.2 Ringkasan kronologi

Waktu	Fase	Aksi penyerang	Teknik ATT&CK
H31 sampai H33	8 Dampak	Portal mati, 500 PC terkunci, layanan berhenti	
H30	7 Serangan	Enkripsi serentak, hapus portal dan backup	T1486, T1485
H28 sampai H30	6 Persiapan	Matikan antivirus, siapkan GPO, hapus shadow copy	T1562.001, T1484.001, T1053.005, T1490
H14 sampai H28	5 Penyebaran senyap	RAT ke 500 PC, eksfiltrasi data	T1021.002, T1569.002, T1041
H7 sampai H14	4 Credential	Keylogging, dump credential, domain admin didapat	T1056.001, T1555.003, T1003.001, T1087.002
H2 sampai H7	3 Gelombang pertama	Watering hole, sekitar 100 PC terinfeksi	T1189, T1203, T1204.002, T1547.001, T1071.001
H0	2 Pijakan	Web shell, domain palsu, loader JavaScript	T1505.003, T1583.001, T1608.004
H0	1 Akses awal	Login superadmin vendor tanpa MFA	T1078
H-30 sampai H-1	0 Pengintaian	Pemetaan subdomain, credential bocor	T1595, T1589.001

4.3 Pemetaan ke kerangka

Tahap NCSC	Cyber Kill Chain	Fase skenario
Survey	Reconnaissance, Weaponization	0, 1, 2
Delivery	Delivery, Exploitation	3
Breach	Installation, Command and Control	3, 4, 5
Affect	Actions on Objectives	5 (eksfiltrasi), 6, 7, 8

4.4 Mengapa penyerang menunggu

Serangan terhadap satu PC dapat langsung diisolasi dan dipulihkan. Serangan serentak terhadap 500 PC dan backup sekaligus membuat instansi tidak memiliki satu pun perangkat untuk merespons, sehingga daya tawar tebusan maksimal. Pilihan waktu Jumat malam memberi penyerang dua hari tanpa pengawasan. Pola menahan diri ini sejalan dengan gambaran CISA tentang penyerang SolarWinds yang sabar dan bertahan lama di jaringan korban, serta dengan pola ransomware modern.

Bab 5 Aktor dan Akar Masalah

Insiden ini bukan kegagalan satu pihak. Vendor membuka pintu masuk, tim TI instansi menyerahkan kunci domain, dan tidak ada pihak yang memantau selama 30 hari.

5.1 Siapa melakukan apa, kapan, dan berapa lama

Aktor	Tindakan dalam insiden	Kapan dan berapa lama	Kegagalan kontrol
Penyerang	Mengintai, masuk, menyebar, mencuri data, lalu mengenkripsi	H-30 sampai H30, total 60 hari; 30 hari di dalam sistem	Pelaku
Developer vendor	Memakai ulang password superadmin yang kemudian bocor	Sebelum H-30	Password dipakai ulang, perangkat terkena infostealer
Vendor (organisasi)	Membiarkan panel superadmin terbuka tanpa MFA, unggah plugin aktif di produksi, tanpa pemantauan integritas berkas, backup di server yang sama	Sejak portal beroperasi; celah tidak terdeteksi selama 30 hari	Akses istimewa lemah, tanpa log yang dipantau, backup tidak terpisah
Operator instansi	Membuka panel admin dari browser yang belum di-patch; sebagian menjalankan pop-up palsu	H2 sampai H7	Patch browser tertinggal, kesadaran keamanan rendah

Aktor	Tindakan dalam insiden	Kapan dan berapa lama	Kegagalan kontrol
Tim TI instansi	Login ke PC terinfeksi memakai akun domain admin	H12, satu kali login yang menentukan	Tanpa pemisahan akun admin (tiering), tanpa EDR
Admin instansi	Tidak mengawasi pemenuhan keamanan vendor dan tidak memiliki rencana kelangsungan layanan	Sepanjang masa kontrak	Tata kelola vendor dan BCP tidak ada
Instansi (organisasi)	Tidak membatasi lalu lintas keluar, tidak memantau GPO dan beacon, backup NAS satu jaringan	H2 sampai H30, 28 hari beacon tidak terdeteksi	Tanpa SIEM dan SOC, tanpa segmentasi, backup tidak offline
Masyarakat	Tidak terinfeksi; menjadi pihak terdampak saat layanan berhenti dan data bocor	H31 dan seterusnya	Bukan pihak yang gagal; subjek data yang dirugikan
BSSN	Dilibatkan untuk koordinasi penanganan dan forensik	Mulai H33	Berperan saat respons
Aparat penegak hukum	Penyidikan aspek pidana	Mulai H33	Berperan saat respons

5.2 Metrik waktu insiden

Metrik	Nilai dalam skenario
Waktu penyerang di dalam sistem sebelum serangan (dwell time)	30 hari
Waktu sampai instansi menyadari insiden	33 hari

Metrik	Nilai dalam skenario
Waktu dari domain admin dicuri sampai 500 PC dikuasai	16 hari
Jumlah peringatan yang ditindaklanjuti sebelum H30	0

5.3 Akar masalah

1. **Akses vendor yang terlalu terbuka.** Akun paling berkuasa atas portal hanya dilindungi satu password dan dapat diakses dari mana saja.
2. **Identitas instansi yang tidak dipisahkan.** Akun domain admin dipakai di PC biasa, sehingga satu PC terinfeksi cukup untuk menguasai seluruh domain.
3. **Tidak ada pemantauan.** Perubahan berkas portal, beacon dari ratusan PC, dan perubahan Group Policy tidak terlihat oleh siapa pun selama 30 hari.
4. **Cadangan tidak terpisah.** Backup instansi dan vendor berada di jaringan atau server yang sama dengan sistem utama, sehingga ikut hancur.
5. **Tidak ada rencana kelangsungan layanan.** Saat portal mati, tidak ada portal cadangan maupun prosedur manual untuk melayani masyarakat.

Bab 6 Model Pertahanan A.E.G.I.S

Setiap fase serangan meninggalkan jejak yang dapat ditangkap. Titik deteksi termurah ada di fase 2: bila perubahan berkas JavaScript portal tertangkap pada H0, belum ada satu PC pun yang terinfeksi.

6.1 Platform yang sudah ada

A.E.G.I.S (Automated Extraction, Gathering, and Intelligence System) adalah platform investigasi yang sudah berjalan dengan enam fitur: OSINT Map, War Room, Entity Graph, Judol Scanner, integrasi Wazuh SIEM, dan Hermes AI Agent. Teknologinya meliputi Next.js 14, FastAPI dengan SQLAlchemy async, Celery dengan Redis, PostgreSQL 17 dengan pgvector, RoBERTa bahasa Indonesia untuk NLP, Wazuh Manager dan Indexer, serta Hermes Agent dari Nous Research.

Hermes AI Agent saat ini menjalankan empat fungsi: chat atas hasil investigasi, briefing otomatis setelah job selesai, analisis anomali dan sentimen, serta smart investigation yang menyusun strategi dan query lanjutan. Tanpa Hermes, A.E.G.I.S tetap berjalan dengan

analisis berbasis template.

6.2 Delapan modul pertahanan untuk skenario ini

Modul berikut adalah rancangan untuk kasus ini, belum diuji di lingkungan produksi. Mesin deteksi berjalan sebagai tugas Celery yang deterministik dan dapat diaudit; Hermes membaca temuannya, tetapi tidak mengambil keputusan aksi.

Modul	Fungsi	Fase yang ditangkap	Sinyal dalam skenario
M1 Web Integrity	Mengambil berkas portal secara berkala dari jaringan instansi, membandingkan hash berkas dan DOM	2, 3	`app.js` berubah di luar jadwal deployment; iframe ke domain asing
M2 Attack Surface	Memetakan aset vendor dan CVE-nya	0, 1	Panel superadmin terbuka ke internet, versi plugin rentan
M3 Infection Tracker	Membaca alert Wazuh dan Sysmon dari PC	3, 4	Browser menjalankan proses baru, Run key baru, akses ke LSASS
M4 C2 Beacon	Menganalisis log DNS dan proxy: interval koneksi dan entropi domain	3, 5	Ratusan host menghubungi domain yang sama dengan interval teratur
M5 IOC Correlator	Mencocokkan domain dan hash dengan feed BSSN, MISP, dan ThreatFox	2, 3	Domain mirip CDN cocok dengan indikator yang dikenal
M6 Attack Graph	Membangun graf situs, host, akun, dan C2; mencari patient zero	4, 5, 6	Satu akun domain admin login ke puluhan PC dalam sehari; perubahan GPO
M7 Response Playbook	Isolasi host, blokir domain C2, nonaktifkan akun, hanya setelah analis menyetujui	Semua fase	Dijalankan atas usulan Hermes dan persetujuan analis
M8 Data Leak	Memantau situs kebocoran dan forum untuk data instansi	5, 8	Sampel data pemohon muncul di situs pemerasan

M1 sengaja dirancang mengambil berkas dari sisi instansi, bukan dari server vendor. Dengan begitu, deteksi tetap berjalan walaupun kontrak tidak memberi instansi akses ke log vendor (Kasus B pada Bab 8).

6.3 Contoh alur deteksi

1. H0, pukul 03.10: M1 mendeteksi hash `app.js` berubah tanpa catatan deployment.
2. Hermes membaca selisih berkas, menemukan loader yang memuat iframe ke domain baru, dan menandainya sebagai skrip berisiko tinggi dengan merujuk ID alert M1.
3. M5 memeriksa domain tersebut: terdaftar dua hari sebelumnya dan meniru nama CDN.
4. M3 dan M4 diperiksa: belum ada PC yang menghubungi domain itu.
5. Hermes menyusun briefing di War Room beserta usulan: blokir domain di DNS instansi, minta vendor menurunkan portal dan mengganti credential superadmin.
6. Analis SOC meninjau bukti dan menyetujui; M7 memblokir domain. Rantai serangan putus sebelum fase 3.

Bila deteksi baru terjadi di fase 5, alurnya sama, tetapi Hermes juga merangkai alert M3, M4, dan M6 menjadi daftar host terinfeksi dan akun yang perlu dinonaktifkan.

6.4 Pengaman untuk Hermes

Pengaman	Penerapan
Human-in-the-loop	Hermes hanya mengusulkan; isolasi, blokir, dan penonaktifan akun butuh persetujuan analis
Konten sebagai data	Skrip berbahaya dan data bocoran dapat berisi prompt injection, sehingga dianalisis tanpa akses ke aksi
Berbasis bukti	Setiap kesimpulan wajib merujuk ID alert, host, atau log untuk menekan halusinasi
Jejak audit	Chat, pemanggilan tool, usulan, dan persetujuan tersimpan di basis data
Mode fallback	Tanpa Hermes, deteksi tetap berjalan dan briefing memakai template
Hanya defensif	Pemindaian hanya pada aset instansi dan vendor yang berizin; aksi hanya di jaringan instansi

6.5 Keterbatasan

A.E.G.I.S belum memiliki angka evaluasi untuk skenario ini. Langkah berikutnya adalah menguji modul pada lingkungan simulasi dan mengukur tingkat deteksi serta false positive. A.E.G.I.S juga tidak menggantikan kontrol dasar: MFA, patch, pemisahan akun admin, dan backup offline tetap harus ada.

Bab 7 Mitigasi Berbasis Skenario

Mitigasi disusun dari titik gagal di Bab 4 dan 5, bukan dari daftar umum. Prinsipnya dua: memutus rantai serangan sedini mungkin, dan menjaga layanan tetap berjalan bila rantai itu tidak sempat diputus.

7.1 Respons saat insiden

Respons mengikuti fungsi Respond dan Recover pada NIST SP 800-61r3.

Waktu sejak diketahui (H33)	Tindakan	Pelaksana
Jam pertama	Aktifkan tim respons; putus koneksi internet dan isolasi segmen jaringan tanpa mematikan daya PC agar bukti di memori terjaga; blokir domain C2; nonaktifkan akun domain admin dan superadmin vendor	Tim TI instansi, vendor
Jam pertama	Turunkan portal dan ganti dengan halaman pemberitahuan; aktifkan layanan alternatif (lihat 7.3)	Admin instansi, vendor
24 jam	Laporkan ke BSSN; amankan bukti (image disk, log, sampel malware); tetapkan cakupan: host, akun, dan data terdampak	Tim TI, BSSN
Paling lambat 3 x 24 jam	Beritahu pemohon terdampak dan lembaga pelindungan data sesuai Pasal 46 UU PDP	Instansi sebagai pengendali data

Waktu sejak diketahui (H33)	Tindakan	Pelaksana
72 jam	Reset seluruh credential, termasuk akun layanan dan akun krbtgt domain; cabut web shell; ganti seluruh credential vendor	Tim TI, vendor
Keputusan tebusan	Tidak membayar tebusan; keputusan diambil pimpinan bersama BSSN dan aparat penegak hukum	Pimpinan instansi
1 sampai 4 minggu	Bangun ulang domain dan reimage PC secara bertahap dari image bersih; pulihkan portal dari cadangan yang terverifikasi bersih	Tim TI, vendor
30 hari setelah pulih	Pemantauan intensif untuk tanda penyerang kembali; laporan akhir dan pelajaran insiden	Tim TI, A.E.G.I.S

7.2 Mitigasi jangka panjang per titik gagal

Fase	Titik gagal	Kontrol pencegah	Pemilik
0, 1	Superadmin bisa diakses dari internet dengan password saja	MFA wajib, akses panel hanya lewat VPN atau daftar IP, akun bernama, pengelola password, peringatan login tidak lazim	Vendor, diwajibkan kontrak
2	Plugin dan web shell dapat diunggah lewat panel produksi	Unggah kode lewat panel dinonaktifkan; perubahan hanya lewat pipeline deployment yang tercatat	Vendor
2, 3	Perubahan `app.js` tidak terdeteksi	Pemantauan integritas berkas (M1), Content Security Policy, Subresource Integrity	Vendor dan instansi

Fase	Titik gagal	Kontrol pencegah	Pemilik
3	Browser pegawai belum di-patch, pop-up palsu dijalankan	Patch browser otomatis dan terpusat, application allowlisting, pelatihan kesadaran keamanan	Instansi
3, 5	Beacon ke C2 tidak terdeteksi	Kontrol lalu lintas keluar lewat proxy, DNS filtering, deteksi beacon (M4)	Instansi
4	Domain admin login ke PC biasa	Pemisahan akun admin bertingkat (tiering): akun domain admin hanya untuk domain controller; PC dikelola dengan akun lokal unik (LAPS); EDR di semua PC	Instansi
5, 6	Penyebaran massal dan perubahan GPO tidak terlihat	Pemantauan pembuatan service dan perubahan GPO (M6), segmentasi jaringan per bidang	Instansi
6, 7	Backup ikut terenkripsi	Backup 3-2-1 dengan satu salinan offline atau immutable; backup vendor terpisah dari server produksi	Instansi dan vendor
8	Layanan berhenti total	Portal cadangan dan rencana kelangsungan layanan (7.3)	Instansi, vendor bila diwajibkan kontrak

Kontrol paling menentukan adalah pemisahan akun admin di fase 4. Tanpa credential domain admin, penyerang terhenti di sekitar 100 PC dan tidak dapat memicu serangan serentak lewat Group Policy.

7.3 Kelangsungan layanan: portal cadangan

Kelumpuhan pada fase 8 menunjukkan bahwa instansi membutuhkan cara lain untuk tetap melayani masyarakat. Pelajaran dari PDNS 2 menguatkan hal ini: pengelola pusat data tidak memiliki backup, sehingga pemulihan layanan bergantung pada backup masing-masing instansi (Investortrust).

Syarat portal cadangan (DR site) agar benar-benar berguna:

1. Berada di infrastruktur yang berbeda dari portal utama, misalnya penyedia hosting atau pusat data lain.
2. Memakai credential administrasi yang berbeda, sehingga akun superadmin portal utama tidak dapat menjangkaunya. Portal cadangan yang dikelola dengan akun yang sama akan ikut jatuh.
3. Tidak tergabung dalam domain Active Directory instansi.
4. Menerima data dari portal utama secara satu arah, dengan salinan harian yang tidak dapat diubah.
5. Diuji peralihannya setiap 6 bulan, dengan pegawai benar-benar memproses permohonan dari portal cadangan.

Komponen rencana kelangsungan layanan (BCP dan DRP):

Komponen	Isi
Target pemulihan	RTO 4 jam untuk layanan pengajuan izin; RPO 24 jam
Prioritas layanan	Pengajuan dan pemantauan izin dipulihkan lebih dulu, fitur lain menyusul
Perangkat cadangan	Stok laptop bersih dengan image standar yang disimpan terpisah dari jaringan, cukup untuk petugas inti
Prosedur manual	Loket offline dengan formulir kertas dan nomor registrasi sementara, untuk dimasukkan ulang setelah pulih
Komunikasi publik	Kanal pengumuman di luar portal, misalnya media sosial resmi dan situs pemerintah kota, dengan templat pesan yang sudah disiapkan
Latihan	Simulasi tabletop dan uji peralihan minimal dua kali setahun

7.4 Urutan penerapan

Jangka	Kontrol
30 hari	MFA dan pembatasan akses panel superadmin; pemisahan akun admin; satu salinan backup offline; penonaktifan unggah plugin di produksi
3 bulan	EDR di seluruh PC; kontrol lalu lintas keluar; A.E.G.I.S modul M1, M3, dan M4; patch browser terpusat
12 bulan	Portal cadangan di infrastruktur terpisah; BCP dan DRP teruji; segmentasi jaringan; revisi kontrak dan dokumen pengadaan sesuai Kontrak A

Bab 8 Analisis Tanggung Jawab

Pihak yang paling bertanggung jawab berubah menurut isi kontrak, tetapi hanya untuk jalur masuk dan kelumpuhan portal. Penyebaran ke 500 PC dan kewajiban kepada masyarakat tetap menjadi tanggung jawab instansi dalam kedua kasus. Agar tidak bias, analisis memakai dua kontrak yang identik kecuali klausul keamanannya (lihat lampiran: Kontrak A dan Kontrak B).

8.1 Tiga lapis tanggung jawab

Lapis	Pertanyaan	Dasar	Dipengaruhi kontrak?
Pidana	Siapa pelaku kejahatan?	Ketentuan pidana akses ilegal dan perusakan sistem elektronik	Tidak. Pelaku selalu penyerang
Kepada masyarakat dan regulator	Siapa yang menanggung di hadapan subjek data dan negara?	UU 27/2022 Pasal 46, 47, dan 51; PP 71/2019 Pasal 2 dan 3	Tidak. Instansi adalah pengendali data dan PSE lingkup publik

Lapis	Pertanyaan	Dasar	Dipengaruhi kontrak?
Antara instansi dan vendor	Siapa menanggung kerugian di antara keduanya?	Kontrak; Perpres 16/2018 dan perubahannya Pasal 78; KUHPerdata	Ya, sepenuhnya bergantung pada isi kontrak

Pada lapis kedua, vendor berposisi sebagai prosesor data. Tanggung jawab baru beralih ke prosesor bila ia memproses data di luar perintah pengendali. Dalam skenario ini, yang mengambil data adalah penyerang, bukan vendor, sehingga pengecualian itu tidak berlaku dan instansi tetap menanggung kewajiban pemberitahuan 3 x 24 jam.

8.2 Kasus A: kontrak mengatur keamanan siber

Kontrak A mewajibkan MFA untuk akun istimewa (Pasal 11), menutup akses panel dari internet (Pasal 10 ayat 4), melarang unggah kode lewat panel produksi dan mewajibkan pemantauan integritas berkas (Pasal 13), mewajibkan log yang dikirim ke SIEM instansi (Pasal 14), serta backup terpisah dan situs pemulihan (Pasal 17). Pasal 24 ayat (2) menegaskan bahwa serangan siber yang berhasil karena kewajiban itu tidak dipenuhi bukan keadaan kahar.

- **Vendor paling bertanggung jawab atas fase 0 sampai 2 dan atas lamanya portal lumpuh.** Vendor melanggar Pasal 10, 11, 13, 14, dan 17. Itu wanprestasi dan tergolong pelanggaran berat menurut Pasal 21 ayat (4): dapat dikenai pencairan jaminan, pemutusan kontrak, usulan daftar hitam, dan ganti rugi sampai nilai kontrak, atau tanpa batas bila terbukti kelalaian berat (Pasal 22).
- **Instansi tetap bertanggung jawab atas fase 3 sampai 8 di jaringannya sendiri.** Browser yang tidak di-patch, domain admin yang login ke PC biasa, lalu lintas keluar yang terbuka, dan backup NAS di jaringan yang sama berada di luar ruang lingkup vendor. Pasal 22 ayat (3) secara tegas membebaskan vendor dari kerugian akibat kelalaian instansi atas perangkat dan jaringannya.
- **Instansi juga lalai mengawasi.** Kontrak A memberi hak audit (Pasal 18) dan laporan triwulanan (Pasal 12 dan 17), tetapi pelanggaran vendor tidak terdeteksi. Ini menjadi temuan pengawasan internal terhadap pejabat yang bertanggung jawab.

8.3 Kasus B: kontrak tidak mengatur keamanan siber

Kontrak B hanya mewajibkan vendor melaksanakan pekerjaan "dengan baik" sesuai KAK (Pasal 6 ayat 4), pemeliharaan sebatas kesalahan fungsi (Pasal 9), dan ketersediaan yang "diupayakan" (Pasal 10). Dua klausul memperburuk posisi instansi: Pasal 14 ayat (2) membebaskan vendor dari gangguan yang disebabkan pihak ketiga dan membatasi ganti rugi 10% nilai kontrak, dan Pasal 16 ayat (1) memasukkan peretasan sebagai keadaan kahar.

- **Instansi paling bertanggung jawab atas hampir seluruh insiden.** Instansi tidak mensyaratkan keamanan sejak penyusunan KAK dan kontrak, tidak mengawasi vendor, dan tidak memiliki rencana kelangsungan layanan. Pejabat pengadaan yang menyusun dokumen dapat dimintai pertanggungjawaban internal.
- **Vendor sulit dituntut lewat kontrak.** Tidak ada klausul keamanan yang dilanggar, dan vendor dapat berlindung di balik klausul keadaan kahar dan pembatasan tanggung jawab.
- **Vendor masih dapat dipersoalkan di luar kontrak.** Membiarkan panel superadmin terbuka tanpa MFA dan memakai ulang password dapat diajukan sebagai kelalaian atau perbuatan melawan hukum (KUHPerdata Pasal 1365 dan 1366). Jalur ini harus dibuktikan di pengadilan dan hasilnya tidak pasti.

8.4 Matriks tanggung jawab

Bagian insiden	Kasus A	Kasus B
Akses awal dan web shell (fase 0 sampai 2)	Vendor	Instansi; vendor hanya lewat gugatan kelalaian
Infeksi gelombang pertama (fase 3)	Instansi, sebagian vendor karena loader tidak terdeteksi	Instansi
Domain admin dan penyebaran ke 500 PC (fase 4 dan 5)	Instansi	Instansi
Backup dan portal lumpuh (fase 6 sampai 8)	Vendor untuk portal, instansi untuk PC dan NAS	Instansi
Pemberitahuan kepada subjek data dan lembaga	Instansi, dibantu vendor	Instansi
Pemulihan kerugian dari vendor	Realistis, sampai nilai kontrak	Hampir tidak ada

8.5 Kesimpulan analisis

Dengan satu kontrak saja, kesimpulan akan bias: Kontrak A seolah menunjuk vendor sebagai pihak bersalah, dan Kontrak B seolah membebaskannya. Dengan dua kasus terlihat bahwa kontrak hanya menentukan siapa yang menanggung **jalur masuk**. Hal yang mengubah satu akun bocor menjadi 500 PC lumpuh selama berhari-hari, yaitu pengelolaan akun admin, patch, pemantauan, dan backup di jaringan instansi, tetap menjadi tanggung jawab instansi di kedua kasus. Kontrak yang baik memindahkan sebagian risiko, tetapi tidak menggantikan kontrol keamanan instansi sendiri.

Bab 9 Kesimpulan dan Saran

9.1 Kesimpulan

1. Serangan berhasil karena kegagalan berlapis. Akun superadmin vendor tanpa MFA membuka jalan masuk, akun domain admin yang dipakai di PC biasa membuka jalan ke seluruh jaringan, dan ketiadaan pemantauan membuat penyerang bebas bergerak selama 30 hari.

2. Penyerang sengaja menahan diri sampai menguasai sekitar 500 PC dan backup, lalu menyerang serentak pada Jumat malam. Pola ini memaksimalkan kelumpuhan dan daya tawar tebusan.
3. Setiap fase meninggalkan jejak yang dapat dideteksi. Titik termurah ada pada perubahan berkas JavaScript portal di H0. A.E.G.I.S dan Hermes dapat mempercepat korelasi dan briefing, tetapi keputusan aksi tetap pada analis, dan modulnya masih perlu diuji.
4. Mitigasi terpenting adalah pemisahan akun admin, MFA pada akses istimewa, backup offline, dan portal cadangan yang benar-benar terpisah, agar layanan publik tetap berjalan walaupun sistem utama lumpuh.
5. Kontrak menentukan siapa yang menanggung jalur masuk: vendor pada Kasus A, instansi pada Kasus B. Namun penyebaran ke 500 PC dan kewajiban kepada masyarakat tetap menjadi tanggung jawab instansi dalam kedua kasus.

9.2 Saran

Untuk	Saran
Instansi	Memasukkan kewajiban keamanan siber ke dalam KAK dan kontrak setiap pengadaan sistem, mengikuti pola Kontrak A
Instansi	Menerapkan kontrol 30 hari pada Bab 7.4, dimulai dari pemisahan akun admin dan backup offline
Instansi	Menyusun dan menguji BCP serta portal cadangan minimal dua kali setahun
Vendor	Menerapkan MFA, pembatasan akses panel, dan pipeline deployment sebagai standar layanan, bukan hanya bila diminta kontrak
Pengembangan A.E.G.I.S	Menguji modul M1, M3, dan M4 pada lingkungan simulasi dan mengukur tingkat deteksi serta false positive

Daftar Pustaka

Regulasi

- Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi. Pasal 46, pasal.id; BPK
- Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik. Justisio
- Peraturan Presiden Nomor 16 Tahun 2018 tentang Pengadaan Barang/Jasa Pemerintah beserta perubahannya. Ringkasan sanksi Pasal 78: SIP Law Firm
- Meridian Hukum. Pengendali vs Prosesor Data Pribadi menurut UU PDP. Tautan

Kerangka

- Nelson, A., Rekhi, S., Souppaya, M., Scarfone, K. (2025). NIST SP 800-61r3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. NIST CSRC
- MITRE ATT&CK Enterprise Matrix. attack.mitre.org

Kasus serupa

- Investortrust (2024). Telkom: Data Pemerintah yang Diserang Ransomware Tak Bisa Dipulihkan. Tautan
- Bisnis.com (2024). Kemenkominfo Sebut 239 Instansi Terdampak PDNS 2 Down. Tautan
- CISA (2020). AA20-352A: Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations. Tautan
- Security Affairs (2017). Watering hole attacks on Polish Banks Linked to Lazarus Group. Tautan
- Help Net Security (2017). Banks around the world targeted in watering hole attacks. Tautan
- Dark Reading (2014). Target Breach: HVAC Contractor Systems Investigated. Tautan
- SC World (2013). U.S. Department of Labor web page serves watering hole attack. Tautan

Lampiran

- Contoh Kontrak Pengembangan Portal Perizinan (Kasus A dan B). Dokumen

Contoh Kontrak Pengembangan Portal Perizinan (Kasus A dan B)

Catatan pengantar

Dua kontrak di bawah memuat pekerjaan, nilai, dan para pihak yang sama. Bedanya hanya satu: Kontrak A mengatur kewajiban keamanan siber secara rinci, sedangkan Kontrak B tidak. Keduanya dipakai untuk menguji siapa pihak yang paling bertanggung jawab atas insiden RAT dan ransomware pada portal perizinan, tanpa bias satu kontrak.

- **Status dokumen:** contoh akademik untuk Tugas Cyber Security, Magister Informatika Universitas AMIKOM Yogyakarta. Bukan dokumen hukum dan bukan nasihat hukum.
- **Nama fiktif:** Pemerintah Kota Mahakarya, Dinas Penanaman Modal dan Pelayanan Terpadu Satu Pintu (DPMPTSP), PT Arunika Data Teknologi, dan sistem SIPerizinan semuanya fiktif. Nama orang ditulis sebagai isian dalam kurung siku.
- **Format:** disederhanakan dari pola kontrak pengadaan barang/jasa pemerintah. Kontrak asli memakai Surat Perjanjian, Syarat-Syarat Umum Kontrak (SSUK), dan Syarat-Syarat Khusus Kontrak (SSKK) yang terpisah; di sini semuanya digabung agar mudah dibaca.
- **Rujukan regulasi:** UU 27/2022 tentang Pelindungan Data Pribadi, PP 71/2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik, dan Perpres 16/2018 tentang Pengadaan Barang/Jasa Pemerintah beserta perubahannya. Nomor pasal perlu dicek ulang pada versi terbaru sebelum dikutip di laporan.
- **Cara membaca:** pasal yang hanya ada di Kontrak A adalah Pasal 10 sampai 18, serta penyesuaian di Pasal 22 dan 24. Perbandingan lengkapnya ada di bagian terakhir.

Kontrak A: dengan klausul keamanan siber

SURAT PERJANJIAN PEKERJAAN PENGEMBANGAN, HOSTING, DAN PEMELIHARAAN SISTEM INFORMASI PERIZINAN (SIPerizinan) Nomor: 027/045-PPK/DPMPTSP/2025

Pada hari ini, Senin, tanggal tiga Maret tahun dua ribu dua puluh lima, bertempat di Kota Mahakarya, kami yang bertanda tangan di bawah ini:

1. **[Nama PPK]**, Pejabat Pembuat Komitmen pada Dinas Penanaman Modal dan Pelayanan Terpadu Satu Pintu Kota Mahakarya, berkedudukan di Jalan Merdeka Nomor 10, Kota Mahakarya, dalam hal ini bertindak untuk dan atas nama Pemerintah

Kota Mahakarya, selanjutnya disebut **PIHAK PERTAMA** atau **Instansi**.

2. **[Nama Direktur]**, Direktur Utama PT Arunika Data Teknologi, berkedudukan di Jalan Teknologi Nomor 88, Kota Mahakarya, dalam hal ini bertindak untuk dan atas nama perseroan, selanjutnya disebut **PIHAK KEDUA** atau **Penyedia**.

PIHAK PERTAMA dan PIHAK KEDUA, selanjutnya bersama-sama disebut **Para Pihak**, dengan memperhatikan Peraturan Presiden Nomor 16 Tahun 2018 tentang Pengadaan Barang/Jasa Pemerintah beserta perubahannya, Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik, dan Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi, sepakat mengikatkan diri dalam perjanjian ini dengan ketentuan sebagai berikut.

Pasal 1: Definisi

1. **SIPerizinan** adalah sistem informasi perizinan berbasis web milik PIHAK PERTAMA, terdiri atas halaman publik untuk masyarakat, panel admin untuk pegawai PIHAK PERTAMA, dan panel superadmin untuk PIHAK KEDUA.
2. **Akun Istimewa** adalah akun dengan hak superadmin, akses server, akses basis data, atau akses ke pipeline deployment.
3. **Insiden Keamanan** adalah kejadian yang mengancam atau telah merusak kerahasiaan, keutuhan, atau ketersediaan SIPerizinan atau data di dalamnya, termasuk dugaan akses tidak sah.
4. **Data Pribadi** adalah data pemohon izin dan pegawai yang diproses melalui SIPerizinan sebagaimana dimaksud dalam UU 27/2022.
5. **Lingkungan Produksi** adalah server dan layanan tempat SIPerizinan dijalankan untuk pengguna sebenarnya.
6. **Situs Pemulihan Bencana (DR Site)** adalah lingkungan cadangan yang terpisah secara infrastruktur dan kredensial dari Lingkungan Produksi.
7. **RTO** adalah batas waktu maksimal layanan pulih setelah gangguan. **RPO** adalah batas maksimal data yang boleh hilang, diukur dalam waktu.
8. **Hari** adalah hari kalender, kecuali disebut hari kerja.

Pasal 2: Dokumen Kontrak

1. Dokumen kontrak terdiri atas: (a) Surat Perjanjian ini; (b) adendum, bila ada; (c) Lampiran I Kerangka Acuan Kerja (KAK); (d) Lampiran II Matriks Tingkat Layanan dan Keamanan; (e) Lampiran III Perjanjian Pemrosesan Data Pribadi; (f) penawaran PIHAK KEDUA.

2. Apabila terdapat pertentangan, berlaku urutan prioritas sesuai urutan pada ayat (1).

Pasal 3: Ruang Lingkup Pekerjaan

1. Pengembangan SIPerizinan sesuai KAK, meliputi analisis, desain, pemrograman, pengujian, dan migrasi data dari sistem lama.
2. Penyediaan hosting di pusat data yang berlokasi di Indonesia, termasuk Lingkungan Produksi dan DR Site.
3. Pengelolaan operasional dan pemeliharaan selama masa layanan, termasuk pemantauan, pembaruan, dan penambalan kerentanan.
4. Pelatihan bagi admin dan operator PIHAK PERTAMA.
5. Penyerahan kode sumber, dokumentasi teknis, dan kredensial seluruh komponen kepada PIHAK PERTAMA.

Pasal 4: Nilai Kontrak dan Cara Pembayaran

1. Nilai kontrak adalah Rp1.480.000.000 (satu miliar empat ratus delapan puluh juta rupiah), sudah termasuk pajak.
2. Pembayaran dilakukan bertahap: 30% setelah serah terima tahap pengembangan, 20% setelah lulus uji penetrasi pra-operasi sebagaimana Pasal 10, dan 50% dibayar triwulanan selama masa layanan.
3. Pembayaran triwulanan hanya dilakukan setelah PIHAK KEDUA menyerahkan laporan triwulanan sebagaimana Pasal 12 ayat (4) dan Pasal 17 ayat (6).

Pasal 5: Jangka Waktu

1. Tahap pengembangan: 150 hari sejak tanggal Surat Perintah Mulai Kerja.
2. Masa layanan hosting, pengelolaan, dan pemeliharaan: 24 bulan sejak serah terima tahap pengembangan.

Pasal 6: Hak dan Kewajiban Para Pihak

1. PIHAK PERTAMA berhak menerima hasil pekerjaan sesuai kontrak, mengawasi pelaksanaan pekerjaan, dan melakukan audit sebagaimana Pasal 18.
2. PIHAK PERTAMA wajib membayar sesuai Pasal 4, menyediakan data dan akses yang dibutuhkan, menunjuk penanggung jawab teknis, dan mengamankan perangkat serta jaringan miliknya yang dipakai untuk mengakses SIPerizinan.
3. PIHAK KEDUA berhak menerima pembayaran sesuai Pasal 4.

4. PIHAK KEDUA wajib melaksanakan pekerjaan sesuai kontrak, memenuhi kewajiban keamanan pada Pasal 10 sampai Pasal 17, dan mematuhi peraturan perundang-undangan.

Pasal 7: Personel dan Subkontrak

1. PIHAK KEDUA wajib menyediakan personel inti sesuai penawaran, termasuk satu orang penanggung jawab keamanan informasi yang memiliki sertifikasi keamanan yang diakui.
2. Penggantian personel inti memerlukan persetujuan tertulis PIHAK PERTAMA.
3. Subkontrak hanya boleh dilakukan dengan persetujuan tertulis PIHAK PERTAMA. Subkontraktor terikat pada kewajiban keamanan dan pelindungan data yang sama, dan PIHAK KEDUA tetap bertanggung jawab penuh atas subkontraktornya.

Pasal 8: Serah Terima Pekerjaan

1. Serah terima tahap pengembangan dilakukan setelah: (a) uji penerimaan pengguna dinyatakan lulus; (b) uji penetrasi pra-operasi selesai dan seluruh temuan kritis dan tinggi telah diperbaiki; (c) kode sumber, dokumentasi, dan kredensial telah diserahkan.
2. Serah terima akhir dilakukan pada akhir masa layanan, disertai serah data dan transisi sesuai Pasal 26.

Pasal 9: Pemeliharaan dan Dukungan

1. PIHAK KEDUA wajib memperbaiki kesalahan fungsi dan kerentanan keamanan selama masa layanan, tanpa biaya tambahan.
2. PIHAK KEDUA wajib menyediakan layanan bantuan pada hari kerja pukul 07.00 sampai 17.00 dan saluran darurat 24 jam untuk Insiden Keamanan.
3. Waktu tanggap dan waktu penyelesaian diatur dalam Lampiran II.

Pasal 10: Standar Keamanan Sistem

1. PIHAK KEDUA wajib mengembangkan SIPerizinan dengan siklus pengembangan aman, setidaknya memenuhi OWASP Application Security Verification Standard Level 2 atau standar setara yang disetujui PIHAK PERTAMA.
2. Sebelum operasi, PIHAK KEDUA wajib memfasilitasi uji penetrasi oleh pihak independen yang disetujui PIHAK PERTAMA. Seluruh temuan kritis dan tinggi wajib diperbaiki dan diuji ulang sebelum SIPerizinan dioperasikan.

3. Uji penetrasi independen diulang setiap 12 bulan dan setiap kali ada perubahan besar pada SIPerizinan.
4. Panel superadmin dan panel admin tidak boleh dapat diakses langsung dari internet publik, kecuali melalui VPN atau daftar IP yang disetujui PIHAK PERTAMA.
5. Seluruh komunikasi wajib terenkripsi dengan TLS 1.2 atau lebih baru.

Pasal 11: Pengelolaan Akun Istimewa

1. Setiap Akun Istimewa wajib menggunakan autentikasi multifaktor.
2. Setiap Akun Istimewa wajib atas nama perorangan. Akun bersama dilarang.
3. Kredensial Akun Istimewa wajib disimpan dalam pengelola kata sandi atau brankas kredensial, dan tidak boleh dipakai ulang pada sistem lain.
4. Perangkat yang dipakai personel PIHAK KEDUA untuk mengakses Akun Istimewa wajib dilindungi anti-malware yang aktif dan sistem operasi yang mutakhir.
5. PIHAK KEDUA wajib mencabut akses personel yang keluar atau berganti tugas paling lambat 1 x 24 jam.
6. Para Pihak melakukan reviu daftar Akun Istimewa setiap 3 bulan.
7. Setiap login Akun Istimewa dari lokasi atau waktu yang tidak lazim wajib memicu peringatan kepada PIHAK KEDUA dan PIHAK PERTAMA.

Pasal 12: Manajemen Kerentanan dan Penambalan

1. PIHAK KEDUA wajib memantau kerentanan pada seluruh komponen SIPerizinan, termasuk framework, plugin, pustaka, sistem operasi, dan server web.
2. PIHAK KEDUA wajib memasang patch dalam batas waktu sejak patch tersedia: kritis 7 hari, tinggi 14 hari, sedang 30 hari, rendah 90 hari.
3. PIHAK KEDUA wajib melakukan pemindaian kerentanan setiap bulan.
4. PIHAK KEDUA wajib menyerahkan laporan triwulanan berisi temuan, status penambalan, dan alasan setiap penundaan.
5. Penundaan patch hanya sah bila disetujui tertulis oleh PIHAK PERTAMA dan disertai kontrol pengganti.

Pasal 13: Integritas Kode dan Konten

1. Perubahan pada Lingkungan Produksi hanya boleh dilakukan melalui pipeline deployment yang tercatat dan disetujui. Pengunggahan tema, plugin, atau berkas kode melalui panel web pada Lingkungan Produksi dinonaktifkan.

2. PIHAK KEDUA wajib memasang pemantauan integritas berkas pada seluruh berkas aplikasi, termasuk berkas JavaScript, dengan peringatan otomatis kepada Para Pihak setiap ada perubahan di luar deployment yang disetujui.
3. PIHAK KEDUA wajib menerapkan Content Security Policy dan Subresource Integrity untuk skrip pihak ketiga.
4. PIHAK KEDUA wajib menyimpan salinan referensi berkas produksi yang bersih untuk pembanding dan pemulihan.

Pasal 14: Pencatatan Log dan Pemantauan

1. PIHAK KEDUA wajib mencatat sekurang-kurangnya: login dan aktivitas Akun Istimewa, perubahan berkas dan konfigurasi, akses ke basis data, dan lalu lintas ke panel admin.
2. Log disimpan paling singkat 12 bulan, terlindungi dari perubahan, dan disinkronkan dengan sumber waktu yang sama.
3. PIHAK KEDUA wajib mengirim log keamanan secara mendekati waktu nyata ke sistem SIEM milik PIHAK PERTAMA.
4. PIHAK KEDUA wajib menyerahkan log yang diminta PIHAK PERTAMA, BSSN, atau aparat penegak hukum dalam rangka penanganan insiden.

Pasal 15: Pelindungan Data Pribadi

1. Dalam pemrosesan Data Pribadi, PIHAK PERTAMA berkedudukan sebagai Pengendali Data Pribadi dan PIHAK KEDUA sebagai Prosesor Data Pribadi.
2. PIHAK KEDUA hanya memproses Data Pribadi berdasarkan perintah tertulis PIHAK PERTAMA dan untuk tujuan kontrak ini.
3. PIHAK KEDUA wajib mengenkripsi Data Pribadi saat disimpan dan saat dikirim, serta menyimpannya di wilayah Indonesia.
4. PIHAK KEDUA wajib membantu PIHAK PERTAMA memenuhi kewajiban pemberitahuan kegagalan pelindungan Data Pribadi dalam 3 x 24 jam sebagaimana UU 27/2022.
5. Rincian pemrosesan diatur dalam Lampiran III.

Pasal 16: Penanganan dan Pelaporan Insiden Keamanan

1. PIHAK KEDUA wajib melaporkan Insiden Keamanan kepada PIHAK PERTAMA paling lambat 12 jam sejak diketahui, termasuk insiden yang masih berupa dugaan.

2. Laporan awal memuat sekurang-kurangnya: waktu diketahui, sistem terdampak, dugaan penyebab, dan langkah penahanan yang sudah diambil.
3. Laporan lanjutan diserahkan paling lambat 3 x 24 jam sejak diketahui, dan laporan akhir paling lambat 14 hari setelah insiden dinyatakan tertangani.
4. PIHAK KEDUA wajib mengamankan bukti digital, tidak menghapus log atau berkas terdampak tanpa persetujuan PIHAK PERTAMA, dan bekerja sama dalam investigasi forensik.
5. PIHAK KEDUA wajib mengikuti arahan PIHAK PERTAMA dalam koordinasi dengan BSSN dan aparat penegak hukum.
6. Para Pihak melakukan latihan tabletop penanganan insiden paling sedikit sekali setahun.

Pasal 17: Kelangsungan Layanan, Cadangan, dan Pemulihan Bencana

1. PIHAK KEDUA wajib menjamin ketersediaan SIPerizinan paling sedikit 99,5% per bulan, di luar pemeliharaan terjadwal yang disetujui.
2. PIHAK KEDUA wajib melakukan cadangan data harian dengan pola 3-2-1: tiga salinan, pada dua media berbeda, dan satu salinan di luar lokasi yang bersifat offline atau tidak dapat diubah (immutable).
3. PIHAK KEDUA wajib menyediakan DR Site yang terpisah dari Lingkungan Produksi, dengan kredensial administrasi yang berbeda dan tidak dapat diakses menggunakan Akun Istimewa Lingkungan Produksi.
4. Target pemulihan: RTO 4 jam dan RPO 24 jam.
5. PIHAK KEDUA wajib menguji pemulihan dari cadangan setiap 3 bulan dan menguji peralihan ke DR Site setiap 6 bulan, disaksikan PIHAK PERTAMA.
6. Hasil uji dilaporkan dalam laporan triwulanan.

Pasal 18: Hak Audit

1. PIHAK PERTAMA, atau pihak ketiga yang ditunjuknya, berhak mengaudit pemenuhan Pasal 10 sampai Pasal 17 dengan pemberitahuan 5 hari kerja.
2. Dalam hal terjadi Insiden Keamanan, audit dapat dilakukan tanpa pemberitahuan terlebih dahulu.
3. PIHAK KEDUA wajib memberikan akses ke dokumen, sistem, log, dan personel yang relevan.
4. Temuan audit wajib ditindaklanjuti sesuai batas waktu pada Pasal 12 ayat (2) menurut tingkat risikonya.

Pasal 19: Kerahasiaan

1. Para Pihak wajib menjaga kerahasiaan informasi yang diperoleh dari pelaksanaan kontrak ini.
2. Kewajiban kerahasiaan tetap berlaku selama 5 tahun setelah kontrak berakhir.

Pasal 20: Hak Kekayaan Intelektual dan Kode Sumber

1. Hak atas SIPerizinan, kode sumber, desain, dan dokumentasi yang dibuat untuk kontrak ini menjadi milik PIHAK PERTAMA.
2. PIHAK KEDUA wajib menyerahkan kode sumber terbaru setiap triwulan dan setiap kali diminta.

Pasal 21: Denda dan Sanksi

1. Keterlambatan penyelesaian tahap pengembangan dikenai denda 1/1000 dari nilai tahap pengembangan per hari keterlambatan.
2. Keterlambatan penambalan melewati batas Pasal 12 ayat (2) dikenai denda 1/1000 dari nilai pembayaran triwulan berjalan per kerentanan per hari.
3. Ketersediaan di bawah target Pasal 17 ayat (1) dikenai pengurangan pembayaran triwulan berjalan sesuai Lampiran II.
4. Pelanggaran Pasal 11, Pasal 13, Pasal 16, atau Pasal 17 ayat (3) yang berkontribusi pada Insiden Keamanan merupakan pelanggaran berat, yang dapat dikenai pencairan jaminan, pemutusan kontrak, dan usulan sanksi daftar hitam sesuai peraturan pengadaan barang/jasa pemerintah.

Pasal 22: Ganti Rugi dan Batas Tanggung Jawab

1. PIHAK KEDUA wajib mengganti kerugian PIHAK PERTAMA yang timbul karena PIHAK KEDUA tidak memenuhi Pasal 10 sampai Pasal 17, termasuk biaya investigasi forensik, pemulihan sistem, pemberitahuan kepada subjek data, dan layanan pengganti.
2. Batas tanggung jawab PIHAK KEDUA paling banyak sebesar nilai kontrak, kecuali kerugian timbul karena kesengajaan atau kelalaian berat PIHAK KEDUA.
3. PIHAK KEDUA tidak bertanggung jawab atas kerugian yang timbul semata-mata karena kelalaian PIHAK PERTAMA dalam mengamankan perangkat, jaringan, dan akun miliknya.

Pasal 23: Jaminan Pelaksanaan dan Jaminan Pemeliharaan

1. PIHAK KEDUA menyerahkan jaminan pelaksanaan sebesar 5% dari nilai kontrak sebelum penandatanganan.
2. PIHAK KEDUA menyerahkan jaminan pemeliharaan sebesar 5% dari nilai kontrak yang berlaku sampai akhir masa layanan.

Pasal 24: Keadaan Kahar

1. Keadaan kahar adalah keadaan di luar kehendak Para Pihak yang tidak dapat diperkirakan, seperti bencana alam, kebakaran, perang, dan huru-hara.
2. Serangan siber tidak dianggap keadaan kahar apabila serangan tersebut berhasil karena PIHAK KEDUA tidak memenuhi Pasal 10 sampai Pasal 17.
3. Pihak yang mengalami keadaan kahar wajib memberitahukan secara tertulis paling lambat 14 hari sejak terjadinya.

Pasal 25: Pemutusan Kontrak

1. PIHAK PERTAMA dapat memutus kontrak apabila PIHAK KEDUA: (a) melakukan pelanggaran berat sebagaimana Pasal 21 ayat (4); (b) tidak memperbaiki pelanggaran dalam 30 hari setelah teguran tertulis kedua; atau (c) terbukti memberikan keterangan palsu.
2. Pemutusan kontrak tidak menghapus kewajiban PIHAK KEDUA berdasarkan Pasal 16, Pasal 19, Pasal 22, dan Pasal 26.

Pasal 26: Pengakhiran dan Transisi

1. Pada akhir atau pemutusan kontrak, PIHAK KEDUA wajib menyerahkan seluruh data, kode sumber, konfigurasi, dan kredensial, serta membantu peralihan kepada penyedia baru paling lama 60 hari.
2. Setelah serah terima, PIHAK KEDUA wajib memusnahkan salinan Data Pribadi dan menyerahkan berita acara pemusnahan.

Pasal 27: Penyelesaian Perselisihan

1. Perselisihan diselesaikan terlebih dahulu secara musyawarah paling lama 30 hari.
2. Apabila musyawarah tidak berhasil, Para Pihak dapat menggunakan layanan penyelesaian sengketa kontrak pengadaan barang/jasa pemerintah atau mengajukannya ke Pengadilan Negeri Kota Mahakarya.

Pasal 28: Hukum yang Berlaku

Kontrak ini tunduk pada hukum Negara Republik Indonesia.

Pasal 29: Penutup

Surat Perjanjian ini dibuat rangkap dua, masing-masing bermeterai cukup dan mempunyai kekuatan hukum yang sama, serta mulai berlaku sejak ditandatangani Para Pihak.

PIHAK PERTAMA	PIHAK KEDUA
Pejabat Pembuat Komitmen DPMPTSP Kota Mahakarya	Direktur Utama PT Arunika Data Teknologi
[tanda tangan dan cap]	[tanda tangan, meterai, dan cap]
[Nama PPK]	[Nama Direktur]

Lampiran II: Matriks Tingkat Layanan dan Keamanan (ringkas)

Butir	Target	Akibat bila tidak terpenuhi
Ketersediaan portal	99,5% per bulan	Pengurangan pembayaran 2% per 0,5% di bawah target
Patch kritis	7 hari	Denda per kerentanan per hari (Pasal 21 ayat 2)
Patch tinggi	14 hari	Denda per kerentanan per hari (Pasal 21 ayat 2)
MFA seluruh Akun Istimewa	100%	Pelanggaran berat bila berkontribusi pada insiden
Laporan awal insiden	12 jam	Pelanggaran berat bila berkontribusi pada insiden
RTO / RPO	4 jam / 24 jam	Ganti rugi biaya layanan pengganti
Uji restore / uji DR	3 bulan / 6 bulan	Penundaan pembayaran triwulan

Kontrak B: tanpa klausul keamanan siber

SURAT PERJANJIAN PEKERJAAN PENGEMBANGAN, HOSTING, DAN PEMELIHARAAN SISTEM INFORMASI PERIZINAN (SIPerizinan) Nomor: 027/045-PPK/DPMPTSP/2025

Pada hari ini, Senin, tanggal tiga Maret tahun dua ribu dua puluh lima, bertempat di Kota Mahakarya, kami yang bertanda tangan di bawah ini:

1. **[Nama PPK]**, Pejabat Pembuat Komitmen pada Dinas Penanaman Modal dan Pelayanan Terpadu Satu Pintu Kota Mahakarya, berkedudukan di Jalan Merdeka Nomor 10, Kota Mahakarya, dalam hal ini bertindak untuk dan atas nama Pemerintah Kota Mahakarya, selanjutnya disebut **PIHAK PERTAMA**.
2. **[Nama Direktur]**, Direktur Utama PT Arunika Data Teknologi, berkedudukan di Jalan Teknologi Nomor 88, Kota Mahakarya, dalam hal ini bertindak untuk dan atas nama perseroan, selanjutnya disebut **PIHAK KEDUA**.

PIHAK PERTAMA dan PIHAK KEDUA, selanjutnya bersama-sama disebut **Para Pihak**, dengan memperhatikan Peraturan Presiden Nomor 16 Tahun 2018 tentang Pengadaan Barang/Jasa Pemerintah beserta perubahannya, sepakat mengikatkan diri dalam perjanjian ini dengan ketentuan sebagai berikut.

Pasal 1: Definisi

1. **SIPerizinan** adalah sistem informasi perizinan berbasis web yang terdiri atas halaman publik, panel admin, dan panel superadmin.
2. **Pemeliharaan** adalah perbaikan atas kesalahan fungsi SIPerizinan yang tidak sesuai dengan KAK.
3. **Hari** adalah hari kalender, kecuali disebut hari kerja.

Pasal 2: Dokumen Kontrak

1. Dokumen kontrak terdiri atas: (a) Surat Perjanjian ini; (b) adendum, bila ada; (c) Lampiran I Kerangka Acuan Kerja (KAK); (d) penawaran PIHAK KEDUA.
2. Apabila terdapat pertentangan, berlaku urutan prioritas sesuai urutan pada ayat (1).

Pasal 3: Ruang Lingkup Pekerjaan

1. Pengembangan SIPerizinan sesuai KAK, meliputi analisis, desain, pemrograman, pengujian fungsi, dan migrasi data dari sistem lama.
2. Penyediaan hosting untuk menjalankan SIPerizinan.

3. Pemeliharaan selama masa layanan.
4. Pelatihan bagi admin dan operator PIHAK PERTAMA.

Pasal 4: Nilai Kontrak dan Cara Pembayaran

1. Nilai kontrak adalah Rp1.480.000.000 (satu miliar empat ratus delapan puluh juta rupiah), sudah termasuk pajak.
2. Pembayaran dilakukan bertahap: 40% setelah serah terima tahap pengembangan dan 60% dibayar triwulanan selama masa layanan.

Pasal 5: Jangka Waktu

1. Tahap pengembangan: 150 hari sejak tanggal Surat Perintah Mulai Kerja.
2. Masa layanan hosting dan pemeliharaan: 24 bulan sejak serah terima tahap pengembangan.

Pasal 6: Hak dan Kewajiban Para Pihak

1. PIHAK PERTAMA berhak menerima hasil pekerjaan sesuai kontrak dan mengawasi pelaksanaan pekerjaan.
2. PIHAK PERTAMA wajib membayar sesuai Pasal 4 dan menyediakan data yang dibutuhkan.
3. PIHAK KEDUA berhak menerima pembayaran sesuai Pasal 4.
4. PIHAK KEDUA wajib melaksanakan pekerjaan dengan baik sesuai KAK dan menjaga agar SIPerizinan dapat digunakan sebagaimana mestinya.

Pasal 7: Personel dan Subkontrak

1. PIHAK KEDUA wajib menyediakan personel sesuai penawaran.
2. Subkontrak hanya boleh dilakukan dengan persetujuan tertulis PIHAK PERTAMA.

Pasal 8: Serah Terima Pekerjaan

1. Serah terima tahap pengembangan dilakukan setelah uji penerimaan pengguna dinyatakan lulus.
2. Akses superadmin dan pengelolaan server tetap dipegang PIHAK KEDUA selama masa layanan untuk keperluan pemeliharaan.

Pasal 9: Pemeliharaan

1. PIHAK KEDUA wajib memperbaiki kesalahan fungsi yang dilaporkan PIHAK PERTAMA paling lambat 7 hari kerja sejak laporan diterima.
2. Pembaruan perangkat lunak dilakukan oleh PIHAK KEDUA apabila diperlukan.
3. Penambahan fitur di luar KAK tidak termasuk pemeliharaan.

Pasal 10: Hosting dan Ketersediaan Layanan

1. PIHAK KEDUA berupaya menjaga agar SIPerizinan dapat diakses setiap saat.
2. PIHAK KEDUA melakukan pencadangan data secara berkala.
3. PIHAK KEDUA memberitahukan gangguan layanan kepada PIHAK PERTAMA dalam waktu yang wajar.

Pasal 11: Kerahasiaan

1. Para Pihak wajib menjaga kerahasiaan informasi dan data yang diperoleh dari pelaksanaan kontrak ini.
2. Kewajiban kerahasiaan tetap berlaku selama 2 tahun setelah kontrak berakhir.

Pasal 12: Hak Kekayaan Intelektual

Hak atas SIPerizinan dan dokumentasinya menjadi milik PIHAK PERTAMA. Kode sumber diserahkan pada akhir masa layanan.

Pasal 13: Denda

Keterlambatan penyelesaian tahap pengembangan dikenai denda 1/1000 dari nilai tahap pengembangan per hari keterlambatan.

Pasal 14: Ganti Rugi dan Batas Tanggung Jawab

1. PIHAK KEDUA wajib mengganti kerugian langsung PIHAK PERTAMA yang timbul karena kesalahan PIHAK KEDUA dalam melaksanakan pekerjaan.
2. PIHAK KEDUA tidak bertanggung jawab atas kerugian tidak langsung, kehilangan data, atau gangguan yang disebabkan oleh tindakan pihak ketiga.
3. Batas tanggung jawab PIHAK KEDUA paling banyak 10% dari nilai kontrak.

Pasal 15: Jaminan Pelaksanaan dan Jaminan Pemeliharaan

1. PIHAK KEDUA menyerahkan jaminan pelaksanaan sebesar 5% dari nilai kontrak sebelum penandatanganan.
2. PIHAK KEDUA menyerahkan jaminan pemeliharaan sebesar 5% dari nilai kontrak yang berlaku sampai akhir masa layanan.

Pasal 16: Keadaan Kahar

1. Keadaan kahar adalah keadaan di luar kehendak Para Pihak yang tidak dapat diperkirakan, antara lain bencana alam, kebakaran, perang, huru-hara, pemadaman listrik berskala luas, serta gangguan sistem akibat tindakan pihak ketiga, termasuk peretasan dan virus komputer.
2. Pihak yang mengalami keadaan kahar wajib memberitahukan secara tertulis paling lambat 14 hari sejak terjadinya dan dibebaskan dari kewajiban selama keadaan kahar berlangsung.

Pasal 17: Pemutusan Kontrak

PIHAK PERTAMA dapat memutus kontrak apabila PIHAK KEDUA tidak melaksanakan pekerjaan sesuai kontrak dan tidak memperbaikinya dalam 30 hari setelah teguran tertulis kedua.

Pasal 18: Pengakhiran

Pada akhir masa layanan, PIHAK KEDUA menyerahkan data dan kode sumber SIPerizinan kepada PIHAK PERTAMA.

Pasal 19: Penyelesaian Perselisihan

1. Perselisihan diselesaikan terlebih dahulu secara musyawarah paling lama 30 hari.
2. Apabila musyawarah tidak berhasil, Para Pihak dapat menggunakan layanan penyelesaian sengketa kontrak pengadaan barang/jasa pemerintah atau mengajukannya ke Pengadilan Negeri Kota Mahakarya.

Pasal 20: Hukum yang Berlaku

Kontrak ini tunduk pada hukum Negara Republik Indonesia.

Pasal 21: Penutup

Surat Perjanjian ini dibuat rangkap dua, masing-masing bermeterai cukup dan mempunyai kekuatan hukum yang sama, serta mulai berlaku sejak ditandatangani Para Pihak.

PIHAK PERTAMA	PIHAK KEDUA
Pejabat Pembuat Komitmen DPMPTSP Kota Mahakarya	Direktur Utama PT Arunika Data Teknologi
[tanda tangan dan cap]	[tanda tangan, meterai, dan cap]
[Nama PPK]	[Nama Direktur]

Perbandingan: titik gagal skenario terhadap kedua kontrak

Kontrak menentukan siapa yang bersalah atas jalur masuk dan kelumpuhan portal. Penyebaran ke 500 PC dan kewajiban kepada masyarakat tetap ada pada instansi di kedua kasus.

Titik gagal dalam skenario	Kontrak A	Kontrak B	Pihak paling bertanggung jawab (A / B)
Panel superadmin terbuka ke internet, login tanpa MFA (fase 1)	Melanggar Pasal 10 ayat (4) dan Pasal 11 ayat (1) dan (7)	Tidak diatur; Pasal 6 ayat (4) hanya "dengan baik"	Vendor / Instansi (tidak mensyaratkan); vendor hanya lewat gugatan perbuatan melawan hukum
Web shell diunggah lewat fitur plugin (fase 2)	Melanggar Pasal 13 ayat (1)	Tidak diatur	Vendor / Instansi
File JavaScript diubah tanpa terdeteksi (fase 2 sampai 7)	Melanggar Pasal 13 ayat (2) dan Pasal 14	Tidak diatur	Vendor / Instansi

Titik gagal dalam skenario	Kontrak A	Kontrak B	Pihak paling bertanggung jawab (A / B)
Browser PC pegawai tidak di-patch (fase 3)	Kewajiban instansi, Pasal 6 ayat (2); vendor dibebaskan Pasal 22 ayat (3)	Tidak diatur	Instansi / Instansi
Domain admin login ke PC biasa, RAT menyebar ke 500 PC (fase 4 dan 5)	Di luar ruang lingkup vendor	Di luar ruang lingkup vendor	Instansi / Instansi
Backup portal ikut terenkripsi, portal lumpuh (fase serangan)	Melanggar Pasal 17 ayat (2) sampai (4)	Pasal 10 hanya "berkala" dan "berupaya"; Pasal 16 menyebut peretasan sebagai keadaan kahar	Vendor untuk portal, instansi untuk PC / Instansi; vendor dapat berlindung di klausul kahar
Notifikasi kegagalan pelindungan data 3 x 24 jam	Vendor wajib lapor 12 jam dan membantu (Pasal 15 ayat 4, Pasal 16)	Tidak diatur	Instansi tetap wajib sebagai pengendali data di kedua kasus
Ganti rugi kepada instansi	Sampai nilai kontrak, tanpa batas bila kelalaian berat (Pasal 22)	Maksimal 10% nilai kontrak, tindakan pihak ketiga dikecualikan (Pasal 14)	Pemulihan biaya realistis / hampir tidak ada

Dua klausul di Kontrak B layak disorot di laporan karena sering ditemui dalam praktik: Pasal 14 ayat (2) yang mengecualikan gangguan oleh pihak ketiga, dan Pasal 16 ayat (1) yang memasukkan peretasan sebagai keadaan kahar. Keduanya praktis memindahkan seluruh risiko serangan siber kepada instansi. Kontrak A menutup celah ini lewat Pasal 24 ayat (2).